PAYMENT SECURITY | GUIDE

PCI DSS v4.0.1 Transition Guide

New requirements for fintechs and payment processors: MFA, WAF coverage, script management, segmentation testing and SBOMs.

Digital Asset Defenders | October 2026 | Security & Compliance Briefing

PCI DSS v4.0.1 is the current version of the global payment card data security standard. For fintechs and payment processors the hard part is no longer awareness but evidence: showing, continuously, that the controls introduced by v4.0 operate as written. This guide covers the requirements that generate most findings, with implementation steps and detection guidance.

> **Status:** PCI DSS v4.0.1 (June 2024) is a limited revision of v4.0 with clarifications and no new requirements. v4.0 was retired on 31 December 2024, and the future-dated requirements became mandatory on **31 March 2025**. Assessments today are against v4.0.1 in full. Check the PCI SSC document library for any later revision.

1. Who this affects

- Merchants, payment service providers, fintechs, wallets, issuers' processors and any entity that stores, processes or transmits cardholder data, or can affect the security of the cardholder data environment (CDE).
- Kenyan fintechs usually meet PCI DSS through acquirer, card-brand or partner-bank contracts. Validation type (SAQ, ROC/AOC) depends on merchant level or service-provider status.
- Service providers carry extra requirements, including six-monthly segmentation testing and additional scoping and governance controls.

2. The requirements that now drive findings

Req.	What it requires	How to implement	Threat / weakness
8.4.2	MFA for all access into the CDE, not just administrators or remote users	Phishing-resistant MFA (FIDO2, certificate-based) on jump hosts, consoles, VPN, cloud IAM; no bypass for service desk resets	T1078, T1110, T1621 / CWE-308, CWE-287
6.4.2	Automated technical solution (WAF or equivalent) in front of public-facing web apps, detecting and preventing attacks	WAF in blocking mode, tuned rules, log forwarding to SIEM; review of blocks monthly	T1190 / CWE-79, CWE-89, CWE-352
6.4.3	Manage every script loaded and executed in the consumer's browser on payment pages: inventory, written justification, authorisation, integrity assurance	Script register with owner and purpose; CSP allow-list; Subresource Integrity on third-party scripts; remove tag-manager sprawl	T1059.007, T1195.002, T1189 (Magecart) / CWE-829, CWE-79
11.6.1	Change and tamper-detection on payment pages and HTTP headers, evaluated at least weekly	Page and header monitoring tool or CSP reporting; alert on new or modified scripts; weekly review evidence	T1565.001, T1185 / CWE-494
11.4.5 / 11.4.6	Penetration test segmentation controls at least every 12 months; service providers every 6 months	Test from out-of-scope networks into the CDE, including after any segmentation change; retain methodology and results	T1021, T1570 / CWE-923
6.3.2	Inventory of bespoke and custom software and third-party components, to support vulnerability and patch management	SBOM in CycloneDX or SPDX generated in CI; map to CVE/CVSS feeds; owner per component	T1195.001 / CWE-1104, CWE-937
12.5.2	Confirm PCI DSS scope at least every 12 months and on significant change	Data-flow diagrams, system inventory, card-data discovery scans, documented sign-off	Scope creep
12.3.1	Targeted risk analysis for any requirement with a flexible frequency	Documented TRA per requirement, with review cadence and approver	Governance gap
5.4.1	Mechanisms to detect and protect personnel against phishing	Mail gateway anti-phishing, DMARC enforcement, simulations and training	T1566 / CWE-1021
10.4.1.1	Automated log review	SIEM correlation rules replace manual review; alert triage records	T1070 / CWE-778
8.3.6, 8.6.1-8.6.3	12-character minimum passwords; controls for system and application accounts	Password manager and vaulting for service accounts; rotation and no interactive logon	T1078.003 / CWE-798, CWE-521

3. Payment-page script control, in practice

Requirements 6.4.3 and 11.6.1 target skimming attacks that inject JavaScript into checkout pages. A minimum technical baseline:

```
Content-Security-Policy: default-src 'self';
  script-src 'self' https://js.psp.example 'sha384-BASE64HASH';
  connect-src 'self' https://api.psp.example;
  frame-ancestors 'none'; object-src 'none'; base-uri 'self';
  report-uri /csp-report
<script src="https://js.psp.example/v3.js"
  integrity="sha384-BASE64HASH" crossorigin="anonymous"></script>
```

- Prefer hosted payment fields or iframes from your PSP so card data never touches your DOM. SAQ A-eligible merchants must still satisfy the script and header requirements that apply.
- Alert on any CSP violation report or hash change; treat an unexplained new script as an incident (T1059.007).
- Keep the register, approvals and weekly review records. Assessors ask for evidence, not intent.

4. Detection: events to monitor

Control area	Event or source	Use
Authentication	Windows 4624, 4625, 4648, 4768/4769/4771; IdP MFA failure and bypass logs	Brute force, MFA fatigue, abnormal CDE logons
Privilege and accounts	4720, 4722, 4728, 4732, 4756, 4672	New accounts and group changes in CDE
Execution and persistence	4688 with command line, 4698, 7045, Sysmon 1/3/11	Malware, lateral movement, web shells
Log integrity	1102 (audit log cleared), 4719 (audit policy changed)	Anti-forensics (T1070.001)
Web tier	WAF blocks, CSP reports, file-integrity changes on checkout templates	Skimmer injection, defacement
Network	Firewall denies across segmentation boundaries; new flows into CDE	Segmentation drift

5. Transition checklist

- Re-scope: card-data discovery, data-flow diagrams, third-party list with responsibility matrix (12.8, 12.9).
- MFA everywhere into the CDE; remove exceptions; test help-desk reset procedures.
- WAF in prevention mode; payment-page script inventory, CSP, SRI and weekly tamper checks.
- SBOM and component inventory in CI; vulnerability SLAs tied to CVSS (for example critical within 7 days, high within 30 days).
- Segmentation penetration test; service providers schedule the six-monthly cycle.
- Targeted risk analyses documented; automated log review live; phishing controls evidenced.
- Dry-run the ROC/SAQ evidence pack with an internal reviewer before the QSA arrives.

> **Customised approach:** v4.0.1 allows alternative controls that meet an objective, but they need a documented targeted risk analysis and extra assessor testing. Choose the defined approach unless a real technical constraint forces otherwise.